



ISO/IEC 27001:2022

Audit Report 2024

AccuKnox Inc.

By:



Infoguard Cyber Security, Inc.

333 W. San Carlos St. Suite 920

San Jose, CA 95113

www.InfoguardSecurity.com

Table of Contents

1. EXECUTIVE SUMMARY	3
2. COMPANY & SERVICES	3
2.1. SERVICES PROVIDED	3
3. AUDIT INFORMATION	4
3.1. ORGANIZATION INFORMATION	4
3.2. AUDIT INFORMATION	4
3.3. OFFICE LOCATIONS VISITED DURING THIS AUDIT	4
3.4. CERTIFICATION SCOPE	4
4. AUDIT PREPARATION AND METHODOLOGY	5
4.1. AUDIT OBJECTIVES	5
4.2. AUDIT SCOPE:	5
4.3. AUDIT CRITERIA:	5
4.4. AUDIT METHODOLOGY	5
4.5. AUDIT PLANNING	5
5. AUDIT TEST DETAILS	6
6. ANNEX A CONTROLS & AUDIT RESULTS	9
7. AUDIT FINDINGS	23
7.1. AUDIT FINDING DEFINITIONS	23
7.2. Internal AUDIT - NON-CONFORMITIES (NC)	23
8. AGREED FOLLOW-UP ACTIVITIES	24
9. AUDIT CONCLUSIONS AND AUDIT RECOMMENDATIONS	25
9.1. AUDIT CONCLUSIONS	25
9.2. AUDIT RECOMMENDATION	25
10. REVIEW AND ACCEPTANCE OF AUDIT REPORT	25

1. EXECUTIVE SUMMARY

AccuKnox Inc. engaged InfoGuard Cybersecurity ("InfoGuard") to review its Information Security Management System (ISMS) against those requirements detailed within the ISO/IEC 27001:2022 standard. The objective of this engagement was to assess the conformance of the client's defined ISMS as an accredited certification body bound by the procedures detailed within ISO/IEC 17021-1:2015, ISO/IEC 27006:2015 and IAF MD 4:2018, where applicable.

This audit report provides AccuKnox Inc. with the results of the ISO/IEC 27001:2022 Internal Audit conducted between June 1 and September 30, 2024.

The audit team has conducted the audit based on the organization's defined processes in correspondence with the audit plan. The audit conducted by a professional team was a process-based audit with a focus on the significant aspects, risks, and objectives.

This provisional report has been developed in accordance with the requirements described in ISO/IEC 17021-1:2015, ISO/IEC 27006:2015, and IAF MD 4:2018. These standards were utilized as a technical reference and guide for determining the audit approach, such as the required number of audit days and minimum competence of the audit team members. This report details activities and conclusions from the Internal.

This audit was a comprehensive ISO audit and not a sample-based audit.

Conclusion:

During the course of the audit process, the InfoGuard ISO Certified Auditors team has concluded that AccuKnox has established a management system according to the requirements of the standard and has proven overall conformity with the requirements of the standard and the ability of the system to consistently achieve the approved requirements for the services within the scope of AccuKnox organization and on organization's policy and objectives.

Referring to the results of the audit process, AccuKnox has not demonstrated the organization's ISMS maturity, which reflects the effectiveness of operational controls over a minimum period of time required by ISO. As a result, InfoGuard recommends external audit and granting certification for ISO/IEC 27001:2022 to be delayed till technical evidence is collected and analyzed within the next six months.

2. COMPANY & SERVICES

AccuKnox Technologies, Inc., located in Silicon Valley, was founded in 2020 to provide Identity-driven Security for Data, Kubernetes, and Native VM workloads for Private and Public Clouds. AccuKnox provides Zero Trust Run-time Kubernetes Security Solution and provides run-time protection for Kubernetes and other cloud workloads using Kernel Native Primitives such as AppAccuKnoxr, SELinux, and eBPF.

2.1. SERVICES PROVIDED

AccuKnox is a Trust Run-time Kubernetes Security Solution. It provides run-time protection for clients' Kubernetes and other cloud workloads using Kernel Native Primitives such as AppAccuKnoxr, SELinux, and eBPF.

Product Solution Features:

- Identity-driven Security for Data, Kubernetes, and Native VM workloads for Private and Public Clouds
- Automatic generation of policies for client's workload in seconds
- Identity as a perimeter of security it uses SPIFFE ID for network policies
- Anomaly detection to protect against any malicious behavior
- Support for SIEM / SOAR Integrations

3. AUDIT INFORMATION

3.1. ORGANIZATION INFORMATION

Company name:	AccuKnox Inc.
Company address:	333 Ravenswood Ave, Suite AG 138, SRI, Menlo Park, CA 94025
Website:	com
Phone number:	(510) 579 8785
Client representative name:	Nat Natraj, CEO
Client representative email:	N@AccuKnox.com
Total number of employees within the scope:	50

3.2. AUDIT INFORMATION

Audit standard(s):	ISO/IEC 27001:2022
Audit #:	ISO – 15
Audit type:	Internal Audit
Date(s) of audit(s):	June 1 to September 30, 2024
Duration:	4 Months
Lead auditor:	Abe Rahim
Additional team member(s):	Robert Roohparvar
Additional attendees and roles:	N/a

3.3. OFFICE LOCATIONS VISITED DURING THIS AUDIT

The Internal Audit was performed remotely in accordance with IAF MD 4:2018. The organization is remote and fully cloud-hosted. There were no physical locations within the scope of the ISMS for this audit.

Date	Location	Auditor
N/A	N/A	N/A

3.4. CERTIFICATION SCOPE

Scope of Audit	The scope of the ISO/IEC 27001:2022 audit is limited to the Information Security Management System (ISMS) supporting AccuKnox's Software-as-a-Service (SaaS) platform, AWS hosted technology, infrastructure and networks, and Engineering, Security and Human resources departments. This is in accordance with the Statement of Applicability Version 1.1.
Date	October 10, 2024

4. AUDIT PREPARATION AND METHODOLOGY

4.1. AUDIT OBJECTIVES

The audit objectives included the following:

- Determine the conformance of the ISMS to the ISO/IEC 27001 standard, specifically with regard to achieving the objectives of AccuKnox Inc.'s information security policy and AccuKnox maintenance, monitoring, and improvement activities of the ISMS, specifically applicable to the audit scope.
- Effectiveness (maturity) of the procedures and processes for evaluation and review of compliance with relevant information security, specifically applicable to the audit scope.

4.2. AUDIT SCOPE:

The audit scope covered the documentation requirements of the ISO/IEC 27001 standard, as well as the associated testing, which included evidence of the monitoring, maintenance, and operating effectiveness of the ISMS and test of the applicable control framework relevant to the audit scope. The audit program included the following, all relevant to the scope of the audit scope:

- The Information Security Management System (ISMS) controls
- Technological controls
- Operational controls
- Physical and personnel security measures
- Effectiveness of the management system with regard to achieving the certified client's objectives.
- Progress of planned activities aimed at continual improvement.

4.3. AUDIT CRITERIA:

- Clauses 4-10 are requirements under ISO/IEC 27001:2022.
- ISO/IEC 27002:2022 Annex – A security controls as per SOA.
- Policy, Process, and Records related to the above requirements.

4.4. AUDIT METHODOLOGY

The audit team has conducted a process-based audit focusing on the significant aspects, risks, and objectives. The auditors have used audit procedures to collect evidence to validate the conformity of the organization's management system. The use of audit procedures in a systematic way reduces the audit risk and reinforces the objectivity of the audit conclusions.

The audit methods used consisted of remote interviews, virtual observations of activities, review of electronic documentation and records, technical tests, and analysis of sampling via the AWS compliance automation platform. These procedures were deemed to meet the audit objectives completely and effectively.

The analysis procedure allows the audit team to draw conclusions concerning a whole by examining a part. It allows the auditor to estimate the characteristics of a population by directly observing a part of the whole population.

4.5. AUDIT PLANNING

InfoGuard has established an initial contact with the auditee to plan for this audit, including scheduling the dates. The Lead Auditor has validated the feasibility of the audit, the audit objectives, the audit scope, the location, and the audit criteria.

InfoGuard facilitated the offsite documentation review of electronic evidence submissions via the AWS compliance automated platform.

The audit plan was sent to the auditee, and it was discussed during the opening meeting between the audit team and the auditee. The remote audit started with an opening meeting attended by the individuals responsible for the ISMS. The InfoGuard overview, audit purpose, methodology, reporting system, appeal process, and confidentiality were briefly presented to the client during the opening meeting.

There were no deviations or significant issues from the audit plan.

5. AUDIT TEST DETAILS

Notes on usage by the auditor:

Under the column "Status", please use the following key to record your assessment result for each clause:

A = Acceptable, **N/A** = Not Applicable (Out of Scope), **MaNC** = Major Non-conformity, **MiNC** = Minor Non-conformity, **OBS** = Observation, **OPI** = Opportunity for improvement

CLAUSES

Clause Requirement			Number of NC	Status	Audit Evidence (Finding and its Justification)
4. Context of the Organization					
4.1		Understanding the Organization and Its context		Compliant	Information Security Management System(ISMS)Plan2022 - v2. Fully meets the respective clause/control requirement.
4.2		Understanding the Needs and Expectations of Interested Parties		Compliant	Information Security Management System(ISMS)Plan2022 - v2. Fully meets the respective clause/control requirement.
4.3		Determining the scope of the ISMS		Compliant	Information Security Management System(ISMS)Plan2022 - v2. Fully meets the respective clause/control requirement.
4.4		Information security management system		Compliant	Information Security Management System(ISMS)Plan2022 - v2. Fully meets the respective clause/control requirement.
5. Leadership					
5.1		Leadership and commitment		Compliant	Information Security Management System(ISMS)Plan2022 - v2, Information Security Policy - v2. Fully meets the respective clause/control requirement.
5.2		Policy		Compliant	Information Security Management System(ISMS)Plan2022 - v2, Information Security Policy - v2. Fully meets the respective clause/control requirement.
5.3		Organizational roles, responsibilities, and authorities		Compliant	Information Security Management System(ISMS)Plan2022 - v2, Information Security Policy - v2, skills matrix. Fully meets the respective clause/control requirement.
6. Planning					
6.1		Actions to address risks and opportunities			
	6.1.1	General		Compliant	Risk management policy, Risk assessment, Risk Register. Fully meets the respective clause/control requirement.
	6.1.2	Information security risk assessment		Compliant	Risk management policy, Risk assessment, Risk Register. Fully meets the respective clause/control requirement.
	6.1.3	Information security risk treatment		Compliant	Risk management policy, Risk assessment, Risk Register, Information Security Management System(ISMS) plan 2022 - v2. Fully meets the respective clause/control requirement.
6.2		Information security objectives and planning to achieve them		Compliant	Information Security Policy - v2. Fully meets the respective clause/control requirement.
6.3		Planning of Changes		Compliant	Change management policy. Fully meets the respective clause/control requirement.

Clause Requirement			Number of NC	Status	Audit Evidence (Finding and its Justification)
7. Support					
7.1		Resources		Compliant	Information Security Management System(ISMS)Plan2022 - v2, Information Security Policy. Fully meets the respective clause/control requirement.
7.2		Competence		Compliant	Skills matrix, ISMS Plan. Fully meets the respective clause/control requirement.
7.3		Awareness		Compliant	Drata provided training. Fully meets the respective clause/control requirement.
7.4		Communication		Compliant	Communication plan in ISMS. Fully meets the respective clause/control requirement.
7.5		Documented Information			
	7.5.1	General		Compliant	ISMS Plan. Fully meets the respective clause/control requirement.
	7.5.2	Creating and Updating		Compliant	ISMS Plan. Fully meets the respective clause/control requirement.
	7.5.3	Control of documented information	1	OFI	Reviewed ISMS Plan, Data retention policy. It was observed that currently there is no clarity on the process of retention and disposition of the internal documents such as Policies, and Procedures, and other documented information. Team to share the details of the process. Hence, this is considered as Opportunity for Improvement. - Current status – Closed
8. Operation					
8.1		Operational planning and control		Compliant	ISMS Plan. Fully meets the respective clause/control requirement.
8.2		Information security risk assessment		Compliant	Risk management policy, Risk assessment, Risk Register, Information Security Management System(ISMS)Plan2022 - v2. Fully meets the respective clause/control requirement.
8.3		Information security risk treatment		Compliant	Risk management policy, Risk assessment, Risk Register, Information Security Management System(ISMS)Plan2022 - v2. Fully meets the respective clause/control requirement.
9. Performance Evaluation					
9.1		Monitoring, measurement, analysis, and evaluation		Compliant	Risk management policy, Risk assessment, Risk Register, Information Security Management System(ISMS)Plan2022 - v2. Fully meets the respective clause/control requirement.
9.2		Internal Audit			
	9.2.1	General		Compliant	Internal Audit Report - ISO 27001-2022-030723-055541, ISMS Plan. Fully meets the respective clause/control requirement.
	9.2.2	Internal Audit Program		Compliant	Internal Audit Report - ISO 27001-2022-030723-055541, ISMS Plan. Fully meets the respective clause/control requirement.
9.3		Management Review			
	9.3.1	General		Compliant	ISMS PLAN, management review meeting and notes. Fully meets the respective clause/control requirement.

Clause Requirement			Number of NC	Status	Audit Evidence (Finding and its Justification)
	9.3.2	Management Review Inputs		Compliant	ISMS PLAN, management review meeting, and notes. Fully meets the respective clause/control requirement.
	9.3.3	Management Review Results		Compliant	ISMS PLAN, management review meeting, and notes. Fully meets the respective clause/control requirement.
10. Improvement					
10.1		Continual Improvement		Compliant	ISMS Plan. Fully meets the respective clause/control requirement.
10.2		Nonconformity and Corrective Action		Compliant	ISMS PLAN, Risk Register. Fully meets the respective clause/control requirement.

6. ANNEX A CONTROLS & AUDIT RESULTS

Control Objective and Control Description		Number of NC	Status	Audit Evidence (Finding and its Justification)
A.5 Organizational Controls				
5.1	Policies for Information Security Control: Information security policy and topic-specific policies shall be defined, approved by management, published, communicated to, and acknowledged by relevant personnel and relevant interested parties, and reviewed at planned intervals and if significant changes occur.		Conformity	Information Security Policy - v2. Fully meets the respective clause/control requirement.
5.2	Information Security Roles and Responsibilities Control: Information security roles and responsibilities shall be defined and allocated according to the organization's needs.		Conformity	Information Security Management System(ISMS)Plan2022 - v2, Skill Matrix and Roles & Responsibilities (1). Fully meets the respective clause/control requirement.
5.3	Segregation of Duties Control: Conflicting duties and conflicting areas of responsibility shall be segregated.		Conformity	Skill Matrix and Roles & Responsibilities (1). Fully meets the respective clause/control requirement.
5.4	Management Responsibilities Control: Management shall require all personnel to apply information security in accordance with the established information security policy, topic-specific policies, and procedures of the organization.		Conformity	Skill Matrix and Roles & Responsibilities (1).
5.5	Contact with Authorities Control: The organization shall establish and maintain contact with relevant authorities.			ISC-Contact with Authorities & Special Interest Groups-170723-081132. Fully meets the respective clause/control requirement.
5.6	Contact with Special Interest Groups Control: The organization shall establish and maintain contact with special interest groups or other specialist security forums and professional associations.		Conformity	ISC-Contact with Authorities & Special Interest Groups-170723-081132, CISA newsletter screenshot. Fully meets the respective clause/control requirement.

Control Objective and Control Description		Number of NC	Status	Audit Evidence (Finding and its Justification)
A.5 Organizational Controls				
5.7	Threat Intelligence Control: Information relating to information security threats shall be collected and analyzed to produce threat intelligence.		Conformity	AWS_inspector, ISC-ThreatIntelligence-070623-134126. Fully meets the respective clause/control requirement.
5.8	Information Security in Project Management Control: Information security shall be integrated into project management.		Conformity	CI_CD, AppSecOpsProgram, Secure SDLC v1.0, SSDLC[Draft]-Page-2.drawio. Fully meets the respective clause/control requirement.
5.9	Inventory of Information and Other Associated Assets Control: An inventory of information and other associated assets, including owners, shall be developed and maintained.		Conformity	[#INFOSEC-1513] Quarterly Asset Inventory Review, IT Asset List (1), Drata Cloud Assets. Fully meets the respective clause/control requirement.
5.10	Acceptable use of Information and Other Associated Assets Control: Rules for the acceptable use and procedures for handling information and other associated assets shall be identified, documented, and implemented.		Conformity	Acceptable Use Policy (1), Drata All policy acceptance. Fully meets the respective clause/control requirement.
5.11	Return of Assets Control: Personnel and other interested parties as appropriate shall return all the organization's assets in their possession upon change or termination of their employment, contract, or agreement.		Compliant	HR-Off-boarding Checklist V2.0-170723-094828, Actual email of the user screenshot taken sent by the HR. Fully meets the respective clause/control requirement.
5.12	Classification of Information Control: Information shall be classified according to the information security needs of the organization based on confidentiality, integrity, availability, and relevant interested party requirements.		Conformity	Complete with DocuSign AccuKnox MNDA Suma_So, Data Classification Policy. Fully meets the respective clause/control requirement.
5.13	Labeling of Information Control: An appropriate set of procedures for information labeling shall be developed and implemented in accordance with the information classification scheme adopted by the organization.		Conformity	Data Classification Policy, External Emails, Confidential Mode email, Reviewed the sample labeling evidence on the call - policy, management review meeting, emails (external). Fully meets the respective clause/control requirement.

Control Objective and Control Description		Number of NC	Status	Audit Evidence (Finding and its Justification)
A.5 Organizational Controls				
5.14	Information Transfer Control: Information transfer rules, procedures, or agreements shall be in place for all types of transfer facilities within the organization and between the organization and other parties.		Compliant	Data Classification Policy, Data Handling procedure. Fully meets the respective clause/control requirement.
5.15	Access Control Control: Rules to control physical and logical access to information and other associated assets shall be established and implemented based on business and information security requirements.		Conformity	System Access Control Policy. Fully meets the respective clause/control requirement.
5.16	Identity Management Control: The full life cycle of identities shall be managed.		Conformity	Offboarding - Ashish Kumar, Offboarding - Rijul Chauhan, Onboarding - Reshadat Ali, Onboarding- Deepak Meena. Fully meets the respective clause/control requirement.
5.17	Authentication Information Control: Allocation and management of authentication information shall be controlled by a management process, including advising personnel on the appropriate handling of authentication information.		Compliant	AccuKnox Authentication, Google Workspace Password Policy, Google Workspace MFA enabled. Fully meets the respective clause/control requirement.
5.18	Access Rights Control: Access rights to information and other associated assets shall be provisioned, reviewed, modified, and removed in accordance with the organization's topic-specific policy and rules for access control.		Conformity	[#INFOSEC-1513] Quarterly Asset Inventory Review, [#INFOSEC-1480] Quarterly review - Data Deletion for Contract POV terminated customer. Fully meets the respective clause/control requirement.
5.19	Information Security in Supplier Relationships Control: Processes and procedures shall be defined and implemented to manage the information security risks associated with the use of supplier's products or services.		Compliant	Vendor Management Policy. Fully meets the respective clause/control requirement.
5.20	Addressing Information Security Within Supplier Agreements Control: Relevant information security requirements shall be established and agreed upon with each supplier based on the type of supplier relationship.		Conformity	Zendesk-ISO-27701-Certificate-2022, Zendesk ISO-27018-Certificate-2021 (1), Vendor Inventory and Assessment, AWS Health Monitoring, Zendesk Supplier Security Assessment. Fully meets the respective clause/control requirement.

Control Objective and Control Description		Number of NC	Status	Audit Evidence (Finding and its Justification)
A.5 Organizational Controls				
5.21	Managing Information Security in the Information and Communication Technology (ICT) Supply Chain Control: Processes and procedures shall be defined and implemented to manage the information security risks associated with the ICT products and services supply chain.		Conformity	Zendesk-ISO-27701-Certificate-2022, Zendesk-ISO-27018-Certificate-2021 (1), Vendor Inventory and Assessment, AWS Health Monitoring, Zendesk Supplier Security Assessment. Fully meets the respective clause/control requirement.
5.22	Monitoring, Review and Change Management of Supplier Services Control: The organization shall regularly monitor, review, evaluate and manage changes in supplier information security practices and service delivery.		Conformity	Zendesk-ISO-27701-Certificate-2022, Zendesk-ISO-27018-Certificate-2021 (1), Vendor Inventory and Assessment, AWS Health Monitoring, Zendesk Supplier Security Assessment. Fully meets the respective clause/control requirement.
5.23	Information Security for Use of Cloud Services Control: Processes for acquisition, use, management, and exit from cloud services shall be established in accordance with the organization's information security requirements.		Compliant	Zendesk-ISO-27701-Certificate-2022,, Zendesk-ISO-27018-Certificate-2021 (1), Vendor Inventory and Assessment, AWS Health Monitoring, Zendesk Supplier Security Assessment. Fully meets the respective clause/control requirement.
5.24	Information Security Incident Management Planning and Preparation Control: The organization shall plan and prepare for managing information security incidents by defining, establishing and communicating information security incident management processes, roles and responsibilities.		Compliant	Incident Response Plan, SmishingAttack-SecurityIncident-March'2023, Information Security Event. Fully meets the respective clause/control requirement.
5.25	Assessment and Decision on Information Security Events Control: The organization shall assess information security events and decide if they are to be categorized as information security incidents.		Compliant	Incident Response Plan, SmishingAttack-SecurityIncident-March'2023, Information Security Event. Fully meets the respective clause/control requirement.
5.26	Response to Information Security Incidents Control: Information security incidents shall be responded to in accordance with the documented procedures.		Conformity	Incident Response Plan, SmishingAttack-SecurityIncident-March'2023, Information Security Event. Fully meets the respective clause/control requirement.

Control Objective and Control Description		Number of NC	Status	Audit Evidence (Finding and its Justification)
A.5 Organizational Controls				
5.27	Learning from Information Security Incidents Control: Knowledge gained from information security incidents shall be used to strengthen and improve the information security controls.		Compliant	Incident Response Plan, SmishingAttack-SecurityIncident-March'2023, Information Security Event. Fully meets the respective clause/control requirement.
5.28	Collection of Evidence Control: The organization shall establish and implement procedures for the identification, collection, acquisition and preservation of evidence related to information security events.		Compliant	Incident Response Plan, SmishingAttack-SecurityIncident-March'2023, Information Security Event. Fully meets the respective clause/control requirement.
5.29	Information Security During Disruption Control: The organization shall plan how to maintain information security at an appropriate level during disruption.		Conformity	Business Continuity Plan, Disaster Recovery Plan, QuarterlyBCP&DRExecutionMay_2023. Fully meets the respective clause/control requirement.
5.30	ICT Readiness for Business Continuity Control: ICT readiness shall be planned, implemented, maintained and tested based on business continuity objectives and ICT continuity requirements.		Conformity	Business Continuity Plan, Disaster Recovery Plan, QuarterlyBCP&DRExecutionMay_2023. Fully meets the respective clause/control requirement.
5.31	Legal, Statutory, Regulatory and Contractual Requirements Control: Legal, statutory, regulatory and contractual requirements relevant to information security and the organization's approach to meet these requirements shall be identified, documented and kept up to date.		Compliant	Information Security Management System(ISMS)Plan2022 - v2. Fully meets the respective clause/control requirement.
5.32	Intellectual Property Rights Control: The organization shall implement appropriate procedures to protect intellectual property rights.		Conformity	AccuKnox Job Terms & Conditions (1), Information security policy. Fully meets the respective clause/control requirement.
5.33	Protection of Records Control: Records shall be protected from loss, destruction, falsification, unauthorized access and unauthorized release.		Conformity	Data Protection Policy, HD Drata encryption, Risk assessment report, R006 - Windows home edition (technical limitation risk), Data stored on AWS. No data is stored on local systems. Fully meets the respective clause/control requirement.

Control Objective and Control Description		Number of NC	Status	Audit Evidence (Finding and its Justification)
A.5 Organizational Controls				
5.34	Privacy and Protection of Personal Identifiable Information (PII) Control: The organization shall identify and meet the requirements regarding the preservation of privacy and protection of PII according to applicable laws and regulations and contractual requirements.		Conformity	Data Protection Policy, HD Drata encryption. Fully meets the respective clause/control requirement.
5.35	Independent Review of Information Security Control: The organization's approach to managing information security and its implementation including people, processes and technologies shall be reviewed independently at planned intervals, or when significant changes occur.		Conformity	AccuKnox Internal audit report, SOC 2 report, Pen test reports. Fully meets the respective clause/control requirement.
5.36	Compliance with Policies, Rules and Standards for Information Security Control: Compliance with the organization's information security policy, topic-specific policies, rules and standards shall be regularly reviewed.		Conformity	Drata Continuous Compliance 1, Drata Continuous Compliance 2, Security awareness training. Fully meets the respective clause/control requirement.
5.37	Documented Operating Procedures Control: Operating procedures for information processing facilities shall be documented and made available to personnel who need them.		Conformity	EN-Onboarding - Developers-170723-130703, EN-Device compliance-170723-130903, EN- AccuKnox Secure Development Training Module-170723-191448. Fully meets the respective clause/control requirement.
A.6 People Controls				
6.1	Screening Control: Background verification checks on all candidates to become personnel shall be carried out prior to joining the organization and on an ongoing basis taking into consideration applicable laws, regulations and ethics and be proportional to the business requirements, the classification of the information to be accessed and the perceived risks.		Compliant	Need access to AWS stg account and read access to prod account, Background Check Policy, BGC Checks & Status. Fully meets the respective clause/control requirement.

Control Objective and Control Description		Number of NC	Status	Audit Evidence (Finding and its Justification)
A.5 Organizational Controls				
6.2	Terms and Conditions of Employment Control: The employment contractual agreements shall state the personnel's and the organization's responsibilities for information security.		Conformity	AccuKnox Job Terms & Conditions (1), Reviewed Sachin's terms and conditions of employment, confidentiality agreement, and responsibilities after termination clause. Fully meets the respective clause/control requirement.
6.3	Information Security Awareness, Education and Training Control: Personnel of the organization and relevant interested parties shall receive appropriate information security awareness, education and training and regular updates of the organization's information security policy, topic-specific policies and procedures, as relevant to their job function.		Conformity	Security Awareness Training, Security Awareness Training Samples. Fully meets the respective clause/control requirement.
6.4	Disciplinary Process Control: A disciplinary process shall be formalized and communicated to take actions against personnel and other relevant interested parties who have committed an information security policy violation.		Conformity	Information security policy. Fully meets the respective clause/control requirement.
6.5	Responsibilities after Termination or Change of Employment Control: Information security responsibilities and duties that remain valid after termination or change of employment shall be defined, enforced and communicated to relevant personnel and other interested parties.		Conformity	AccuKnox Job Terms & Conditions (1), Reviewed Sachin's terms and conditions of employment, confidentiality agreement, and responsibilities after termination clause. Fully meets the respective clause/control requirement.
6.6	Confidentiality or Non-Disclosure Agreements Control: Confidentiality or non-disclosure agreements reflecting the organization's needs for the protection of information shall be identified, documented, regularly reviewed and signed by personnel and other relevant interested parties.		Conformity	AccuKnox Job Terms & Conditions (1), Reviewed Sachin's terms and conditions of employment, confidentiality agreement, and responsibilities after termination clause. Fully meets the respective clause/control requirement.

Control Objective and Control Description		Number of NC	Status	Audit Evidence (Finding and its Justification)
A.5 Organizational Controls				
6.7	Remote Working Control: Security measures shall be implemented when personnel are working remotely to protect information accessed, processed or stored outside the organization's premises.		Conformity	Teleworking and BYOD policy, Session time out. Fully meets the respective clause/control requirement.
6.8	Information Security Event Reporting Control: The organization shall provide a mechanism for personnel to report observed or suspected information security events through appropriate channels in a timely manner.		Conformity	Incident Response Plan, SmishingAttack-SecurityIncident-March'2023, Information Security Event, Security Awareness training. Fully meets the respective clause/control requirement.
A.7 Physical Controls				
7.1	Physical Security Perimeters Control: Security perimeters shall be defined and used to protect areas that contain information and other associated assets.		Not Applicable	
7.2	Physical Entry Control: Secure areas shall be protected by appropriate entry controls and access points.		Not Applicable	
7.3	Securing Offices, Rooms and Facilities Control: Physical security for offices, rooms and facilities shall be designed and implemented.		Not Applicable	
7.4	Physical Security Monitoring Control: Premises shall be continuously monitored for unauthorized physical access.		Not Applicable	
7.5	Protecting Against Physical and Environmental Threats Control: Protection against physical and environmental threats, such as natural disasters and other intentional or unintentional physical threats to infrastructure shall be designed and implemented.		Not Applicable	

Control Objective and Control Description		Number of NC	Status	Audit Evidence (Finding and its Justification)
A.5 Organizational Controls				
7.6	Working in Secure Areas Control: Security measures for working in secure areas shall be designed and implemented.		Not Applicable	
7.7	Clear Desk and Clear Screen Control: Clear desk rules for papers and removable storage media and clear screen rules for information processing facilities shall be defined and appropriately enforced.		Not Applicable	
7.8	Equipment Siting and Protection Control: Equipment shall be sited securely and protected.		Not Applicable	
7.9	Security of Assets Off-Premises Control: Off-site assets shall be protected.		Not Applicable	
7.10	Storage Media Control: Storage media shall be managed through their life cycle of acquisition, use, transportation and disposal in accordance with the organization's classification scheme and handling requirements.		Not Applicable	
7.11	Supporting Utilities Control: Information processing facilities shall be protected from power failures and other disruptions caused by failures in supporting utilities.		Not Applicable	
7.12	Cabling Security Control: Cables carrying power, data or supporting information services shall be protected from interception, interference or damage.		Not Applicable	
7.13	Equipment Maintenance Control: Equipment shall be maintained correctly to ensure availability, integrity and confidentiality of information.		Not Applicable	

Control Objective and Control Description		Number of NC	Status	Audit Evidence (Finding and its Justification)
A.5 Organizational Controls				
7.14	Secure Disposal or Re-Use of Equipment Control: Items of equipment containing storage media shall be verified to ensure that any sensitive data and licensed software have been removed or securely overwritten before disposal or re-use.		Not Applicable	
A.8 Technological Controls				
8.1	User End Point Devices Control: Information stored on, processed by or accessible via user end-point devices shall be protected.		Conformity	01 MDM Mosyle, 02 Device Information, 03 - Anti-Malware Compliance. Fully meets the respective clause/control requirement.
8.2	Privileged Access Rights Control: The allocation and use of privileged access rights shall be restricted and managed.		Conformity	[#DEVOPS-89] Need access to aws stg account and read access to prod account, AWS and Jenkins Prod Access. Fully meets the respective clause/control requirement.
8.3	Information Access Restriction Control: Access to information and other associated assets shall be restricted in accordance with the established topic-specific policy on access control.		Conformity	ISC-AccuKnoxSaaSPlatformRBAC-150623-135343, System Access Control Policy. Fully meets the respective clause/control requirement.
8.4	Access to Source Code Control: Read and write access to source code, development tools and software libraries shall be appropriately managed.		Conformity	[#INFOSEC-1529]QuarterlyAccessReview-May'23, Reviewed the developers' list of GitHub, GitLab and Jenkins. Fully meets the respective clause/control requirement.
8.5	Secure Authentication Control: Secure authentication technologies and procedures shall be implemented based on information access restrictions and the topic-specific policy on access control.		Conformity	Password policy, User roles, AccuKnox RBAC, Password policy artifact, MFA. Fully meets the respective clause/control requirement.
8.6	Capacity Management Control: The use of resources shall be monitored and adjusted in line with current and expected capacity requirements.		Conformity	Auto Scaling Group Policy, Capacity Management Grafana Screenshot. Fully meets the respective clause/control requirement.

Control Objective and Control Description		Number of NC	Status	Audit Evidence (Finding and its Justification)
A.5 Organizational Controls				
8.7	Protection Against Malware Control: Protection against malware shall be implemented and supported by appropriate user awareness.		Conformity	Anti-malware compliance. Fully meets the respective clause/control requirement.
8.8	Management of Technical Vulnerabilities Control: Information about technical vulnerabilities of information systems in use shall be obtained, the organization's exposure to such vulnerabilities shall be evaluated and appropriate measures shall be taken.		Conformity	Vulnerability Management Policy, App Sec Ops Program, AccuKnox - scans all the environments. Cloud Optics - Sophos - Scan the infrastructure and highlight the misconfiguration. AWS security hub, AWS Inspector, AWS Guardduty. Fully meets the respective clause/control requirement.
8.9	Configuration Management Control: Configurations, including security configurations, of hardware, software, services and networks shall be established, documented, implemented, monitored and reviewed.		Compliant	Benchmark configuration, CICD pipeline, EN-Golden-AMI. Fully meets the respective clause/control requirement.
8.10	Information Deletion Control: Information stored in information systems, devices or in any other storage media shall be deleted when no longer required.		Compliant	Data retention policy, Quarterly review - Contract termination. Fully meets the respective clause/control requirement.
8.11	Data Masking Control: Data masking shall be used in accordance with the organization's topic-specific policy on access control and other related topic-specific policies, and business requirements, taking applicable legislation into consideration.		Conformity	Data Masking Artifact, sensitive data is not stored from the user's point of view, and Vulnerabilities are highlighted, Layered approach, passwords, and end-user passwords are masked. De-identification of the customer -> Tenant-ID is mapped to the customer name. Fully meets the respective clause/control requirement.
8.12	Data Leakage Prevention Control: Data leakage prevention measures shall be applied to systems, networks and any other devices that process, store or transmit sensitive information.		Conformity	DLP Rules. Fully meets the respective clause/control requirement.

Control Objective and Control Description		Number of NC	Status	Audit Evidence (Finding and its Justification)
A.5 Organizational Controls				
8.13	Information Backup Control: Backup copies of information, software and systems shall be maintained and regularly tested in accordance with the agreed topic-specific policy on backup.		Conformity	Backup policy, Data backup configuration. Fully meets the respective clause/control requirement.
8.14	Redundancy of Information Processing Facilities Control: Information processing facilities shall be implemented with redundancy sufficient to meet availability requirements.		Compliant	Multi AZ_ES, Multi AZ RDS. Fully meets the respective clause/control requirement.
8.15	Logging Control: Logs that record activities, exceptions, faults and other relevant events shall be produced, stored, protected and analyzed.		Conformity	AccuKnox Code Platform Logs (1), Drata event and audit logs, Infra and log monitoring, ISC- Logging and monitoring. Fully meets the respective clause/control requirement.
8.16	Monitoring Activities Control: Networks, systems and applications shall be monitored for anomalous behavior and appropriate actions taken to evaluate potential information security incidents		Conformity	AccuKnox Code Platform Logs (1), Drata event and audit logs, Infra and log monitoring, ISC- Logging and monitoring. Fully meets the respective clause/control requirement.
8.17	Clock Synchronization Control: The clocks of information processing systems used by the organization shall be synchronized to approved time sources.		Conformity	GCP. Fully meets the respective clause/control requirement.
8.18	Use of Privileged Utility Programs Control: The use of utility programs that can be capable of overriding system and application controls shall be restricted and tightly controlled.		Compliant	Access Review. Fully meets the respective clause/control requirement.
8.19	Installation of Software on Operational Systems Control: Procedures and measures shall be implemented to securely manage software installation on operational systems.		Compliant	Installed app on End User Device, Risk assessment document - R005, Mosyle - MDM solution in place Fully meets the respective clause/control requirement.

Control Objective and Control Description		Number of NC	Status	Audit Evidence (Finding and its Justification)
A.5 Organizational Controls				
8.20	Network Security Control: Networks and network devices shall be secured, managed and controlled to protect information in systems and applications.		Conformity	Cloud Front_GeoRestrictions, CloudFront_Distribution, CloudFront Behavior, sample ingress and egress rules, Cloud Optix -> CSPM monitors the traffic and flags in case of any issue. Fully meets the respective clause/control requirement.
8.21	Security of Network Services Control: Security mechanisms, service levels and service requirements of network services shall be identified, implemented and monitored.		Conformity	04 AccuKnox Network Architecture Diagram (1), MFA on Identity Provider, Google Workspace MFA enabled. Fully meets the respective clause/control requirement.
8.22	Segregation of Networks Control: Groups of information services, users and information systems shall be segregated in the organization's networks.		Conformity	04 AccuKnox Network Architecture Diagram (1). Fully meets the respective clause/control requirement.
8.23	Web Filtering Control: Access to external websites shall be managed to reduce exposure to malicious content.		Compliant	Web Filtering on Browser, Acceptable use policy. Fully meets the respective clause/control requirement.
8.24	Use of Cryptography Control: Rules for the effective use of cryptography, including cryptographic key management, shall be defined and implemented.		Conformity	Data Encryption Artifact, AWS encryption KMS. Fully meets the respective clause/control requirement.
8.25	Secure Development Life Cycle Control: Rules for the secure development of software and systems shall be established and applied.		Compliant	Secure SDLC v1.0 (1), Software Development Lifecycle Policy. Fully meets the respective clause/control requirement.
8.26	Application Security Requirements Control: Information security requirements shall be identified, specified and approved when developing or acquiring applications.		Conformity	Secure SDLC v1.0 (1), Software Development Lifecycle Policy. Fully meets the respective clause/control requirement.
8.27	Secure System Architecture and Engineering Principles Control: Principles for engineering secure systems shall be established, documented, maintained and applied to any information system development activities.		Conformity	Architecture diagram, Secure SDLC v1.0 (1), Software Development Lifecycle Policy. Fully meets the respective clause/control requirement.
8.28	Secure Coding Control: Secure coding principles shall be applied to software development.		Compliant	EN-AccuKnox Secure Development Training Module-170723-191448. Fully meets the respective clause/control requirement.

Control Objective and Control Description		Number of NC	Status	Audit Evidence (Finding and its Justification)
A.5 Organizational Controls				
8.29	Security Testing in Development and Acceptance Control: Security testing processes shall be defined and implemented in the development life cycle.		Compliant	CICD Pipeline View, Architecture diagram, PT report reviewed. Fully meets the respective clause/control requirement.
8.30	Outsourced Development Control: The organization shall direct, monitor and review the activities related to outsourced system development.		Conformity	Not Applicable
8.31	Separation of Development, Test and Production Environments Control: Development, testing and production environments shall be separated and secured.		Conformity	AccuKnox Prod, AccuKnox QA. Fully meets the respective clause/control requirement.
8.32	Change Management Control: Changes to information processing facilities and information systems shall be subject to change management procedures.		Conformity	[#ENG-29683] Prod Deployment _ R-132 _ 6 July. Fully meets the respective clause/control requirement.
8.33	Test Information Control: Test information shall be appropriately selected, protected and managed.		Compliant	Software Development Lifecycle. Fully meets the respective clause/control requirement.
8.34	Protection of Information Systems During Audit Testing Control: Audit tests and other assurance activities involving assessment of operational systems shall be planned and agreed between the tester and appropriate management.		Conformity	Limited Access to Auditor, Well Plan Audit Schedule. Fully meets the respective clause/control requirement.

7. AUDIT FINDINGS

InfoGuard attempts to communicate all relevant audit findings at the time of identification with its clients in order to encourage a fluid communication model between all participating team members.

The audit findings were communicated to the client representative during the closing meeting. The final conclusion of the audit results and recommendation by the audit team was also communicated to the management during the meetings.

As a result of the Audit, the audit team identified one finding relevant to the ISO/IEC 27001:2022 Maturity standard. This conclusion reflects the same information discussed during the Audit Closing Meeting, which was facilitated by the audit team on October 01, 2024.

7.1. AUDIT FINDING DEFINITIONS

The evaluation of the audit findings is based on the following definitions:

Major Non-Conformities (MaNC)

The absence or total failure of a system to meet a requirement it may be either:

- A number of minor non-conformities against one requirement can represent a total failure of the system and thus be considered a major non-conformity or
- Any non-conformity that would result in the probable shipment of a non-conforming product. A condition that may result in the failure or materially reduce the usability of the products or services for their intended purpose or
- A non-conformity that judgment and experience indicate is likely either to result in the failure of the management system or to materially reduce its ability to assure controlled processes and products.

Minor Non-Conformities (MiNC)

A non-conformity that judgment and experience indicate is not likely to result in the failure of the management system or reduce its ability to assure controlled processes or products. It may be either:

- A failure in some part of the supplier's documented management system relative to the requirement or
- A single observed lapse in following one item of a company's management system.

Observations (OBS)

Any issues that are likely to become an NC, if not treated until the next audit, are marked as observations (OBS).

Opportunities for Improvement (OFI)

If certain aspects that generally comply with the requirements of the standard should be improved, then they are marked as opportunities for improvement (OFI). These OFIs help to improve the management system as a whole or named processes.

7.2. Internal AUDIT - NON-CONFORMITIES (NC)

Ref. No	Clause / Control #	Control/Clause Requirement	Details of Non-Conformities	NC Type	Planned Completion Date
1	8.15	Logs that record activities, exceptions, faults, and other relevant events shall be produced, stored, protected, and analyzed.	Logs must be collected for an additional six months for review and analysis and to demonstrate the system's maturity.		12/30/2024

8. AGREED FOLLOW-UP ACTIVITIES

Non-conformities detailed above need to be addressed through the organization's corrective action process in accordance with the relevant corrective action requirements of the audit standard, including actions to analyze the cause of the non-conformity, prevent recurrence, and complete the maintained records.

Corrective actions to address the identified major non-conformities shall be carried out immediately, and InfoGuard must be notified of the actions taken within 30 days.

Corrective actions to address the identified minor non-conformities shall be documented on an action plan and be sent for review by the client to the auditor within 30 days. If the actions are deemed to be satisfactory, they will be followed up during the next scheduled visit.

Non-conformities shall be addressed through the client's corrective action process, including:

- Actions taken to determine the extent of and contain the specific non-conformity.
- Root Cause (results of an investigation to determine the most basic cause(s) of the non-conformity)
- Actions taken to correct the non-conformity and, in response to the root cause, to eliminate the recurrence of the non-conformity.
- Corrective action response shall be submitted to the Lead Auditor
- The client must maintain corrective action records, including objective evidence, for at least three (3) years.

The following action should be taken by the client:

- ☐ No action is required
- ☐ **MINOR** non-conformities and observations were raised.
- ☒ **MAJOR** non-conformities raised. A corrective action plan must be submitted by AccuKnox to the InfoGuard ISO team by 12/31/2024.

9. AUDIT CONCLUSIONS AND AUDIT RECOMMENDATIONS

AccuKnox Information Security Management System has proven to conform to the requirements of the ISO standard. It has also provided an adequate structure to support the implementation and maintenance of the information security management system.

9.1. AUDIT CONCLUSIONS

Has there been any serious deviation from the audit plan?	No
Are there any significant issues impacting the audit program?	No
Are there any significant changes affecting the management system since the last audit took place?	N/A
Are there any unresolved issues affecting the management system since the last audit took place?	N/A
The management system is designed to achieve the organization's policy objectives.	Yes
The management system meet statutory, regulatory, and contractual requirements?	Yes
The internal audit and management review processes are in place and adequate?	Yes
The audit was successful in meeting the stated objectives?	Yes

9.2. AUDIT RECOMMENDATION

Based on the findings identified during the internal audit, the appointed audit team has concluded that AccuKnox is not yet ready to proceed with an external audit by an ISO Board Auditor Certification Body.

To meet the ISO/IEC 27001:2022 requirements, the audit team strongly recommends the continued collection of technical control evidence over six months. This will demonstrate the maturity and effectiveness of the implemented controls. Successfully fulfilling this requirement will position AccuKnox to qualify for an external audit by the ISO Board Auditor, paving the way for ISO/IEC 27001:2022 certification.

Abe Rahim

ISO Certified Lead Auditor
InfoGuard Cybersecurity

10. REVIEW AND ACCEPTANCE OF AUDIT REPORT

This report was reviewed on October 09, 2024. The Lead Auditor's finding was confirmed and issued.

Robert Roohparvar

Chief Information Security Officer
ISO Certified Implementer
CISSP, CISA, CISM, PCI QSA, CTPRP

InfoGuard Cyber Security

e-mail: Robert@InfoGuardSecurity.com
Phone: (408) 568-9000
(855) 444-6004

Offices: North Cal: Silicon Valley
South Cal: Orange County

Web: www.InfoGuardSecurity.com



"Honoring Two Decades of Trust in Cybersecurity Services"